AegisBank 银行 AI 智能体技术文档

2026 深圳国际金融科技大赛 人工智能赛道

队伍 0xChainAegis 版本日期 2026 年 10 月 25 日

AegisBank 把自然语言金融需求转为可检查的任务计划，在确定性风险和权限控制下执行模拟银行业务。本文面向赛事评委，说明系统架构、核心算法、六类场景、交互闭环及复现方法。核心成果是可审计的执行控制面，所有金融结果均来自 Mock Bank Core。

1 产品目标与实现范围

用户从任务控制台或 IM 适配入口输入需求，系统展示意图、步骤依赖、操作对象和风险原因。低风险查询自动执行；修改业务状态的任务需要明确确认；高风险任务还需演示 MFA。结果、确认和策略证据均可追溯。

场景	当前原型能力	关键边界
智能转账	联系人转账 定时任务 AA 拆分	对象不唯一时澄清
账单分析	分类统计 异常识别 月度年度报告	规则检测 模拟流水
理财操作	产品持仓 风险测评 申购赎回	模拟收益 非投资建议
卡片管理	虚拟卡 额度限额 还款日 挂失	高风险设置强验证
订阅代扣	扣费识别 续费提醒 取消订阅	站内提醒 无外部推送
跨场景联动	账单到取消订阅 生日预算和预订	预置任务组合

默认规则 Planner，无需模型密钥；可配置 OpenAI compatible LLM 或 auto 模式。LLM 只生成结构化候选，不执行工具、不决定权限、不编造金融事实。限定表达和预置组合已落地；通用指代消解、任意多意图与条件执行尚未完整实现。工具覆盖不等于语言表达全面覆盖。

代码依据 config.py；planning/；scenarios/；docs/NLP-ASSESSMENT-AND-PLAN-2026-10-25.md。下文代码路径相对 backend/aegisbank_api/，前端路径另注。

2 系统架构与可信边界



图 1 从用户渠道到模拟银行执行和审计的系统架构

React 19 与 TypeScript 控制台只通过 /api 调用后端。FastAPI 统一承载能力策略、就绪检查、计划、确认和审计接口。所有银行工具经过 gateway.py、executor.py 和 ExecutionGuard；业务事实由 SQLite 仓库读取或更新。

scenarios/ 自动发现业务模块，extensions/ 装配 MFA、熔断、补偿、IM、沙箱和角色能力。新模块可贡献 Schema、种子、工具、意图和风险规则，仍须复用核心网关与执行链。

代码依据 main.py；gateway.py；executor.py；banking/repository.py；scenarios/README.md；extensions/README.md。

3 意图规划与确定性算法

3 1 语言解析与计划编译

输入先检查注入和越权特征，并做金额规范化。规则 Planner 根据场景契约识别工具与参数；LLM 模式输出相同的 ExecutionPlan 契约，再经过字段白名单和关键参数来源检查。未支持的条件或组合转为澄清，避免把带条件请求降为无条件写操作。

PlanCompiler 检查工具注册、参数 Schema、节点标识唯一性、依赖存在性、重复依赖和自依赖。拓扑遍历使用访问状态检测环，再按依赖顺序输出节点；当前每个计划最多 12 个工具节点。标准化意图与步骤以规范 JSON 编码后计算 SHA-256，生成 plan_hash。结构合法不能单独证明语义正确。

3 2 动态风险与最小权限

工具声明基线风险和最小权限。风险引擎读取金额、当日累计、操作类型等确定性事实，最终风险取基线与规则结果的较高者。LLM 置信度不参与降级或授权。节点执行前均由网关复检角色、工具授权和风险，任一拒绝会阻断任务。

风险	执行方式	示例条件
绿色	自动执行	余额 账单 产品 订阅等只读查询
黄色	展示详情并确认	小额转账且预计日累计≤1000 元 取消订阅
红色	确认加演示 MFA	预计日累计>1000 元 挂失 密码修改 理财申购

单笔转账超过 5000 元也是红色触发条件。卡片设置、赎回和定时任务按各自规则判断，不能把一个金额阈值当作所有工具通用的授权条件。风险原因随响应、确认和审计显示。

代码依据 planning/compiler.py；planning/llm.py；planning/rule.py；risk.py；risk_rules.py；gateway.py；scenarios/*。

4 确认执行和跨场景任务

4 1 确认绑定与幂等

ActionEnvelope 绑定用户、计划哈希、步骤和工具、参数哈希、风险、权限、nonce 和有效期。确认后服务端重新计算和比对，任一不一致拒绝执行；已消费 nonce 不能重放。默认确认有效期 300 秒。红色任务还需 MFA Provider 校验，固定 OTP 和模拟生物识别只用于本地演示。

发起和确认使用 Idempotency-Key。同一逻辑请求重试复用原键，返回首次结果或处理中状态；内容变化不能复用原键。断线或超时保留原请求凭据并先查询结果，避免重复产生动作或扣款。刷新快照只用于定位任务，计划和风险必须重新向服务端核对。

4 2 两类跨场景 DAG

账单联动为 query_bill → cancel_subscription。第二步引用第一步实际返回的 suspicious_subscription_id，使取消对象来自本次分析，而不是模型猜测。若不存在目标，应停止并解释。

生日联动为查询联系人生日 → 锁定预算 → 预订鲜花 → 预订蛋糕。服务计划写入定时任务，由到期调度执行，本地可时间快进演示。预算解锁通过补偿链完成。所有预订均为模拟记录，不向真实商户下单。

4 3 暂停回退与人工接管

执行在节点之间暂停，恢复不重复已完成节点。失败后根据 journal 逆序补偿，反向工具同样复检权限和风险。不可逆节点或补偿失败转 UNKNOWN，要求人工对账，不自动重试。RECONCILED 表示已记录核查结论，不代表资金冲正；ROLLED_BACK 仍须核对逐步补偿结果。

代码依据 trust/action_envelope.py；trust/idempotency.py；trust/state_machine.py；scheduler.py；scenarios/automation.py；extensions/compensation.py。

5 前端可靠性与交互闭环

控制台包含银行概览、场景数据、任务、权限、能力演示、运维和审计。概览和场景数据为只读视图；任务页集中呈现指令、计划、风险、确认和回执。权限从 /authz/me 获取，加载失败关闭写入口。readiness 未就绪时同样禁用写操作；服务端独立执行拒绝。

5 1 用户需要检查的执行事实

确认界面显示对象、金额、卡片、操作后果、风险原因和有效期。查询结果、人工确认、策略判断与哈希链校验分别标记来源。前端不能用模型推断或上一轮成功结果代替当前银行事实。业务失败、明确拒绝与结果未知必须分别呈现。

本轮修正包括保留非 JSON 错误的 HTTP 状态、取消后不重复显示为当前异常订阅、未知理财风险保守显示、失败时要求核对记录。每日限额摘要改为读取实际 daily_limit_cny 参数并显示金额，避免用户确认时只看见卡片而看不到新限额。

5 2 断线恢复与异步状态

断线不等于未执行，保留原键查询结果；明确拒绝显示可采取的下一步。角色变化、刷新恢复和异步加载必须以当前后端策略为准。金额与日期分别格式化，长标识和长结果在移动布局中可换行或滚动。浏览器实际检查结果见随附本轮验收记录。

5 3 多渠道连接

IM、CLI 和 webhook 适配器复用同一 Planner、风险、网关、MFA 与审计；message_id 用于重复投递回放。目前是本地协议适配演示，尚未连接真实平台、验证平台签名或绑定真实用户。前端呈现模拟 MFA 提示，不伪装成真实短信或人脸识别。

代码依据 frontend/src/App.tsx；api.ts；viewModel.ts；session.ts；components/ConfirmationModal.tsx；TaskConsolePage.tsx；channels/im.py；extensions/im.py。

6 部署和演示验收

后端需要 Linux 或 WSL 环境，因为 db.py 使用 fcntl，不能直接在原生 Windows 运行。环境为 Python 3.11 及以上，Node 版本遵循 frontend/package.json 的 engines；推荐 uv 与 pnpm 使用锁文件。仅绑定本机。规则模式无需模型密钥；LLM 模式在 backend/.env 配置，真实密钥不能进入代码包。

```
cd backend
uv sync --frozen
uv run uvicorn aegisbank_api.main:app --host 127.0.0.1 --port 8000


# 另开终端 从项目根目录启动前端
cd frontend
pnpm install --frozen-lockfile
pnpm dev
```

访问 http://127.0.0.1:5173；API 文档为 http://127.0.0.1:8000/docs。Vite 将 /api 转发到 8000 端口。SQLite 首次启动初始化模拟种子。重置演示库前先停止后端，避免改动正在使用的数据。

阶段	检查项目	通过依据
启动	就绪 工具清单 当前角色	ready 且权限可用
绿色	账单或产品查询	自动执行 结果与证据可见
黄色	小额转账或取消订阅	先确认 拒绝不执行
红色	挂失或理财申购	错误 MFA 不执行 正确才执行
恢复	注入 撤权 幂等 断线	拒绝有原因 恢复不重复执行
审计	步骤与链校验	任务可定位 valid 为真

当前构建、测试和浏览器验证结果见随附本轮验收记录。历史 deliverables 的测试数量属于旧版快照。自动化通过不等同于生产安全认证、完整渗透测试或真实用户研究。后续重点是通用语义、真实身份与 MFA、平台映射、OS 级隔离和独立审计存储。

代码依据 backend/pyproject.toml；frontend/package.json；frontend/vite.config.ts；scripts/bootstrap.sh；scripts/test.sh；scripts/scenario-check.py；backend/tests/。